Parv Bajaj

Gurugram, IND
(+91) 8814086059
Parvbajaj2000@gmail.com
LinkedIn:// parvbajaj

Senior Product Security Engineer with 5+ years of experience across AppSec, ProdSec, and cloud security, focused on defining security architecture for cloud-native and AI-powered systems. Strong background in threat modeling, CI/CD security, and production incident response, securing web, API, and LLM-based workloads through automation and risk-driven security controls.

PROFESSIONAL EXPERIENCE

Syfe **Gurugram**
Security Engineer (Product Security & Architecture) *November 2025 – Present*

- *Owned application and product security for a cloud-native fintech platform, driving AppSec and ProdSec initiatives across SDLC, CI/CD, cloud infrastructure, and AI-powered systems.*
- *Led evaluation, acquisition, and integration of SAST tools into CI/CD pipelines, defining security gates, triage workflows, and developer remediation processes aligned with SSDLC best practices.*
- *Designed and executed threat modeling for diverse architectures including monolithic, microservices, event-driven systems, and AI/LLM-based workflows, identifying high-impact abuse paths and design-level risks early in development.*
- *Acted as Security On-Call responder, triaging and mitigating production security incidents, coordinating with engineering and SRE teams to reduce MTTR and prevent recurrence.*
- *Built and automated security controls across CI/CD pipelines, enabling continuous security testing, policy enforcement, and secure release workflows.*
- *Lead security efforts for AI/LLM initiatives, including secure integration of LLMs, MCP-based tool access, and automation systems, focusing on prompt injection, tool abuse, data leakage, and confused-deputy risks.*
- *Integrated Wiz CSPM and Sysdig CNAPP findings with Semgrep SAST in security reviews for AWS workloads, correlating code vulns with cloud exposure to prioritize remediation and reduce risk exposure.*
- *Partnered closely with engineering leadership to embed security into design reviews, backlog prioritization, and platform decisions, shifting security left without blocking delivery.*
- *Established repeatable security architecture patterns and review processes adopted across multiple teams, reducing design-level security issues in production systems.*

FinThrive **Gurugram**
Application Security Engineer *April 2024 – November 2025*

- *Conducted penetration testing and security assessments across 35+ products, including web, mobile, APIs, thick clients, and SaaS platforms.*
- *Integrated SAST and DAST (Checkmarx) tools into CI/CD pipelines, improving vulnerability detection and remediation.*
- *Conducted secure design reviews and code audits, enforcing OWASP Top 10, SANS 25, and secure SDLC compliance.*
- *Performed security reviews for cloud-based applications (AWS, Azure, GCP), validating encryption in transit, OAuth/SAML authentication, and RBAC policies.*

- *Developed automated security testing workflows using Python, Bash, Jenkins, and PowerShell, reducing manual pentesting efforts.*
- *Led threat modeling and risk assessment sessions, applying STRIDE framework and MITRE ATT&CK techniques.*
- *Acted as the primary security partner for product teams, influencing roadmaps and backlog prioritization by clearly articulating risk, trade-offs, and business impact.*
- *Launched a bug bounty program pilot, crafted security release process, and delivered developer trainings on secure coding best practices.*
- *Mentored 3 junior security engineers and led cross-functional security reviews for 5+ product teams, establishing technical direction, conducting 1:1s.*

Grant Thornton Bharat LLP **Gurugram**
Sr. Security Consultant *September 2021 – April 2024*

- *Led client-facing penetration testing and security advisory engagements across web applications, APIs, mobile apps, thick clients, and cloud-integrated systems, leveraging Burp Suite, Postman, MobSF, Frida, and echoMirage.*
- *Delivered end-to-end network and infrastructure security assessments, including firewall rule reviews, segmentation analysis, and Active Directory testing using Nmap, Wireshark, and Metasploit, providing prioritized, actionable remediation roadmaps to client engineering teams.*
- *Served as Project Manager for 5+ client security engagements, managing dedicated testing teams (3-5 engineers), scope, timelines, budgets, stakeholder communication, and final deliverables as primary client point-of-contact.*
- *Acted as embedded security team lead (loan staff) within client organizations, owning day-to-day testing coordination, advisory services, and remediation tracking as an extension of their internal engineering teams.*
- *Investigated security incidents through SIEM-based log analysis, identifying root causes, supporting containment efforts, and advising clients on improvements to detection and response capabilities.*
- *Supported client compliance initiatives across GDPR, PCI DSS, and ISO 27001 by translating regulatory requirements into practical security controls and implementation guidance for development teams.*

EDUCATION

The NorthCap University **Gurugram**
B.Tech in Computer Science (Specialization in Cyber Security)

PROJECTS

SubShot

- Built SubShot, a subdomain enumeration tool with HTTP/HTTPS probing and screenshotting capabilities; won 2nd place at Technovation.

NCU CTF

- Organized a CTF sponsored by **Offensive Security**, designing challenges across Web, Reverse Engineering, OSINT, and other domains.

ACHIEVEMENTS & PUBLICATIONS

- **Hall of Fame** - Recognized by hippovideo.io and NCIIPC (x4) for responsible vulnerability disclosure.
- **CVE-2025-56146** - Reported a Missing SSL Certificate Validation vulnerability in the Indian Bank IndSMART Android app, impacting login/OTP/payment flows.
- **Research Paper** - Authored 'Cloud Security – The Future of Data Storage' in Springer book series.
- **Technical Blogging** - Author of in-depth technical blogs covering application security, AI Security, AI PenTesting, and practical exploit development, including detailed Hack The Box (HTB) and TryHackMe (THM) walkthroughs; published on Medium
- **GitHub** — Maintaining active repositories showcasing tools and automation scripts (e.g., SubShot).
- **Conference Speaker** - Presented a talk on "Automating Information Security with Python" sharing insights on developing scripts for security tasks

CERTIFICATIONS

- Certified Red Team Professional (CRTP)
- Web Application Penetration Tester Extreme (eWPTX v2)
- Certified Ethical Hacker (CEH v11)
- Certificate of Cloud Security Knowledge (CCSK)
- Junior Penetration Tester (eJPT)
- Certificate of Competence in Zero Trust (CCZT)
- INE Certified Cloud Associate (ICCA)
- CCNA: Introduction to Networks
- AWS Academy Cloud Graduate
- APIsec Certified Practitioner

SKILLS

- **Penetration Testing & Security Assessments:** Web, Mobile, API, SaaS, Thick Client, Network Security, SAST, DAST, AI Security
- **Cloud & CI/CD Security:** Azure, AWS, GCP, Docker, Kubernetes, Wiz, ORCA Security, Security in DevOps Pipelines
- **Secure SDLC & Threat Modeling:** OWASP Top 10, STRIDE, Secure Design Reviews, OAuth, SAML, RBAC
- **Security Incident Handling & SIEM:** Splunk, CrowdStrike, Threat Analysis, Log Forensics
- **Regulatory Compliance & Security Standards:** GDPR, PCI-DSS, ISO 27001, CIS Benchmarks
- **Programming & Scripting:** Python, Bash, PowerShell, JavaScript, SQL